

TechCorp Vendor Management & SLA Policy

Third-Party Vendor Governance, Contracts & Service Level Agreements

Version: v1.0

Document: TC-VMS-011

TechCorp Internal

1. Purpose & Scope

This policy establishes TechCorp's framework for managing relationships with third-party vendors, software providers, cloud platforms, and professional services firms. It defines how vendors are selected, contracted, monitored, and offboarded, and sets the Service Level Agreement (SLA) standards that all critical vendors must meet.

Applies To	All TechCorp departments procuring external services or software
Policy Owner	VP of Engineering & Head of Procurement
Review Cycle	Annual — or immediately following a major vendor incident
Effective	January 1, 2026
Version	v1.0

2. Vendor Classification

All vendors are classified into tiers based on their criticality to TechCorp's operations and the sensitivity of data they access.

Tier	Label	Criteria	Examples
T1	Critical	Production dependency; handles customer PII/MSA and data	AWS, Auth0, Stripe, PagerDuty
T2	Important	Significant workflow dependency; no customer data	GitHub, Notion, Jira, Slack
T3	Standard	Non-critical tooling; limited data exposure	Figma, Loom, Calendly
T4	Low-risk	One-off or trial services; no data sharing	Conference SaaS, survey tools

3. Vendor Selection Process

- Business need documented in a Vendor Request Ticket (Jira template: VND-REQ)
- Minimum 3 vendors evaluated for any T1/T2 procurement above \$10,000/year
- Security questionnaire (based on CAIQ/SIG Lite) required for T1/T2 vendors
- Legal review of MSA and DPA required before any contract is signed

- Finance approval required for any commitment exceeding \$25,000 annually
 - Final approval matrix: T1 requires VP Eng + CFO sign-off; T2 requires department head
 - Approved vendors added to the TechCorp Vendor Registry within 5 business days
-

4. SLA Requirements by Tier

The following minimum SLA requirements must be contractually guaranteed by vendors in each tier. Failure to meet these thresholds triggers the remediation process in Section 7.

Metric	Tier 1 (Critical)	Tier 2 (Important)	Tier 3 (Standard)
Uptime Guarantee	99.99% / month	99.9% / month	99.5% / month
Planned Maintenance	72h advance notice	48h advance notice	24h advance notice
Incident Response	15 min (P1)	1 hour (P1)	4 hours (P1)
Resolution Target	4 hours (P1)	8 hours (P1)	2 business days
Status Page	Required (public)	Required	Recommended
Support Hours	24/7	Business hours + on-call	Business hours
Data Breach Notice	Within 24 hours	Within 48 hours	Within 72 hours
Audit Rights	Annual + on request	Annual	On request only

5. Contract Requirements

All vendor contracts must include the following clauses:

Master Services Agreement (MSA)	Governs the overall relationship; must be signed before any SOW
Data Processing Agreement (DPA)	Required for any vendor processing personal data (GDPR Article 28)
SLA Schedule	Explicit uptime, response, and resolution commitments with remedies
Service Credits	Credits owed for SLA breaches: typically 10–30% of monthly fee
Termination for Cause	Right to terminate within 30 days if SLA breach is uncured
Termination for Convenience	Right to exit with 90-day notice for T1; 30 days for T2/T3
IP & Data Ownership	TechCorp retains ownership of all data provided to or created by vendor
Confidentiality (NDA)	Mutual NDA; 3-year post-termination obligation minimum
Security Standards	Vendor must maintain SOC 2 Type II or equivalent
Subcontractor Approval	Vendor must notify TechCorp before engaging subprocessors
Governing Law	Contracts governed by laws of the State of California

6. Vendor Onboarding

Step 1: Vendor Request Ticket approved in Jira Step 2: Security questionnaire sent and reviewed (SLA: 5 business days) Step 3: Legal redlines exchanged and MSA/DPA finalized Step 4: Finance creates PO; vendor added to approved payment system Step 5: IT provisions SSO/SCIM integration (mandatory for T1/T2 SaaS) Step 6: Vendor contact details and escalation path logged in Vendor Registry Step 7: Kickoff meeting scheduled; SLA monitoring configured in Grafana/StatusPage

7. SLA Monitoring & Breach Remediation

- T1 vendors: uptime and incident response tracked in real time via status page integrations
- Monthly SLA report auto-generated for all T1/T2 vendors and shared with vendor owners
- Any SLA breach must be formally documented within 48 hours of discovery
- Service credits claimed within 30 days of breach; tracked in Vendor Registry

Escalation thresholds:

1st Breach	Formal written notice; vendor must provide RCA within 5 business days
2nd Breach	Executive escalation call; vendor presents remediation plan
3rd Breach	Contract review triggered; vendor placed on probation status
4th Breach	TechCorp may invoke termination for cause; transition planning begins

8. Data Security & Compliance Requirements

All T1 vendors and any vendor processing personal data must satisfy the following security requirements at contract signing and maintain them throughout the relationship.

Requirement	T1 Mandatory	T2 Required	T3 Recommended
SOC 2 Type II Report	Yes	Yes	No
ISO 27001 Certification	Preferred	Preferred	No
Penetration Test (annual)	Yes	Yes	No
Encryption at Rest (AES-256)	Yes	Yes	Yes
Encryption in Transit (TLS 1.3)	Yes	Yes	Yes
MFA for Admin Access	Yes	Yes	Recommended
Vulnerability Disclosure Policy	Yes	Yes	No
GDPR / CCPA Compliance	Yes	If applicable	If applicable
Zero-Retention Option	Required	Preferred	No

9. Vendor Performance Reviews

Vendor performance is reviewed on a structured cadence to ensure continued alignment with TechCorp's operational and quality standards.

Review Type	Frequency	Participants	Output
T1 Operational Review	Monthly	Vendor owner + SRE lead	SLA scorecard update
T1 Business Review	Quarterly	VP Eng + vendor account exec	QBR report in Notion
T2 Review	Quarterly	Department head + vendor PM	Issue log + action items
Annual Renewal Review	Annual	Procurement + Legal + Finance	Renew / renegotiate / exit
Ad-hoc Incident Review	Per event	SRE + Security + vendor eng	Post-mortem document

10. Vendor Offboarding

Step 1: Notice of termination issued per contract terms (30–90 days) Step 2: Data export requested from vendor within 5 business days of notice Step 3: Data deletion confirmed in writing from vendor within 30 days of contract end Step 4: IT revokes SSO access, deactivates API keys, and removes integrations Step 5: Finance cancels PO and ensures final invoice settlement Step 6: Vendor marked as 'Offboarded' in Vendor Registry; record retained 7 years Step 7: Lessons learned documented if vendor was T1 or if offboarding was for cause

11. Approved Vendor Registry

The TechCorp Vendor Registry is the single source of truth for all active and historical vendor relationships. It is maintained in Notion and updated by the Procurement team within 5 business days of any change.

Location	Notion > Procurement > Vendor Registry (restricted access)
Fields	Vendor name, tier, contract owner, contract dates, SLA scorecard, contacts, DPA status
Access	Read: all employees Write: Procurement team only
Review Owner	Head of Procurement — quarterly audit for accuracy
Integration	Synced with Finance ERP for spend tracking

12. Policy Exceptions

- Exceptions to this policy require written approval from VP Engineering and Head of Procurement
- Emergency vendor use (e.g., incident response tools) may be approved by on-call Engineering Manager with 48-hour retroactive documentation
- Exceptions are logged in the Vendor Registry with justification and expiry date
- No exception may waive the requirement for a DPA when personal data is processed
- All exceptions are reviewed at the annual policy review cycle